SIMANTIK — Dokumen Serah Terima Sistem, Arsitektur & Kesiapan Rilis (Fase 16)

Versi: 1.0.0
Tanggal: 8 Oktober 2026
Pemerintah Daerah Kabupaten Bandung — Dinas Komunikasi dan Informatika
Sistem: SIMANTIK (Sistem Manajemen Layanan Teknologi Informasi)

---

1. Panduan Klasifikasi Dokumentasi

Sesuai standar kejujuran teknis dan akuntabilitas tata kelola perangkat lunak, dokumentasi ini secara eksplisit mengklasifikasikan setiap pernyataan ke dalam 4 kategori:

1. `[CONFIRMED REQUIREMENT]`: Kebutuhan resmi yang telah disetujui dalam PRD, regulasi tata kelola SPBE (Perpres No. 95/2018), atau kebijakan tertulis Diskominfo.
2. `[TECHNICAL IMPLEMENTATION]`: Solusi rekayasa perangkat lunak dan arsitektur kode sumber yang telah diimplementasikan, diuji, dan aktif di repositori.
3. `[IMPLEMENTATION ASSUMPTION]`: Asumsi teknis atau operasional yang diambil oleh tim pengembang untuk melengkapi detail implementasi. Asumsi ini **bukan merupakan kebijakan resmi Diskominfo** sampai disahkan oleh pimpinan.
4. `[OPEN QUESTION]`: Pertanyaan terbuka atau keputusan bisnis/organisasi yang masih memerlukan konfirmasi lebih lanjut dari para pemangku kepentingan Diskominfo.

---

2. Arsitektur Sistem & Batasan Modul (*Module Boundaries*)

A. Gambaran Arsitektur Tiga Lapis (*Three-Tier Architecture*)

- `[CONFIRMED REQUIREMENT]`: Sistem terdiri dari portal publik untuk pemohon OPD (**Web Layanan**), konsol administrasi internal Diskominfo (**Web Admin**), dan layanan backend terpusat yang berbagi basis data tunggal.
- `[TECHNICAL IMPLEMENTATION]`:
  - **Web Layanan (`frontend/service-web`)**: Dibangun menggunakan React 19, Vite, Tailwind CSS. Berjalan tanpa koneksi langsung ke Supabase; 100% interaksi dilakukan melalui NestJS API untuk mencegah ekspos kredensial database ke publik.
  - **Web Admin (`frontend/admin-web`)**: Dibangun menggunakan React 19, Vite, Tailwind CSS. Menggunakan Supabase Auth untuk autentikasi staf internal Diskominfo dan memanggil NestJS

API menggunakan Bearer JWT.

- **Backend API (`backend/api`)**: Dibangun menggunakan NestJS (Express adapter), modular monorepo, TypeScript. Bertindak sebagai pemegang otoritas tunggal (*single source of authority*) dalam validasi alur kerja, penyimpanan berkas, dan otorisasi data.
- **Basis Data & Storage (`supabase`)**: PostgreSQL 15+ dengan Row Level Security (RLS) aktif dan penyimpanan objek privat.

B. Batasan Modul Backend (*Backend Module Boundaries*)

- `[TECHNICAL IMPLEMENTATION]`:
  - `applications`: Bertanggung jawab atas penerimaan permohonan baru, registrasi berkas, dan mesin alur kerja status (*Centralized Workflow Engine*).
  - `assignments`: Bertanggung jawab atas pencatatan dan penegakan batas penugasan teknisi (*technician assignment boundary*).
  - `lifecycle`: Mengelola dokumentasi 7 tahapan siklus hidup SPBE (Analisis, Perencanaan, Perancangan, Implementasi, Pengujian, Pemeliharaan, Evaluasi).
  - `messages`: Mengelola komunikasi tiket dengan pemisahan tegas antara pesan `PUBLIC` dan catatan `INTERNAL`.
  - `notifications`: Mengelola pengiriman notifikasi in-app dan email transaksional via Resend.
  - `tracking`: Mengelola verifikasi kredensial publik tanpa akun (nomor tiket + kode pelacakan rahasia) dan penerbitan token sesi pendek.
  - `auth`: Menangani verifikasi Bearer JWT, pengecekan profil aktif, dan penegakan RBAC endpoint melalui `RolesGuard`.
  - `common/filters`: Global Exception Filter yang menyensor error 500 dan driver database ke klien.

---

3. Domain Basis Data & Kebijakan RLS (*Row Level Security*)

A. Cakupan 18 Tabel Skema Publik

- `[TECHNICAL IMPLEMENTATION]`:
  1. `public.opd_units` — Master data Perangkat Daerah di Kabupaten Bandung.
  2. `public.profiles` — Profil pengguna terautentikasi (nama, peran, status aktif).
  3. `public.services` — Katalog layanan TI (Pengembangan Baru, Penambahan Fitur).
  4. `public.service_requirements` — Persyaratan dokumen dan metadata format per layanan.
  5. `public.applicants` — Data pemohon resmi (PIC) dari OPD pengusul.
  6. `public.applications` — Master tiket permohonan layanan.
  7. `public.application_documents` — Metadata dokumen persyaratan yang dilampirkan.
  8. `public.application_status_history` — Riwayat kronologis mutasi status operasional.
  9. `public.application_stage_history` — Riwayat kronologis mutasi tahapan siklus hidup.

10. `public.assignments` — Riwayat penugasan teknisi utama per tiket.
11. `public.analysis_records` — Dokumentasi tahapan Analisis Kebutuhan SPBE.
12. `public.project_plans` — Dokumentasi tahapan Perencanaan Teknis.
13. `public.design_records` — Dokumentasi tahapan Perancangan Arsitektur & UI/UX.
14. `public.implementation_records` — Dokumentasi tahapan Implementasi & Koding.
15. `public.test_records` — Dokumentasi Pengujian Kelaikan (Fungsi, Integrasi, Beban, Keamanan).
16. `public.maintenance_records` — Dokumentasi Pemeliharaan Sistem (4 jenis pemeliharaan).
17. `public.evaluations` — Dokumentasi Evaluasi Pasca-Implementasi & Dampak SPBE.
18. `public.messages` — Pesan komunikasi tiket (publik & internal).
19. `public.notifications` — Antrean notifikasi pengguna in-app & status kirim email.
20. `public.audit_logs` — Jejak audit sistem anti-perubahan (*append-only*).

B. Kebijakan Default Deny

- `[CONFIRMED REQUIREMENT]`: Klien web tidak boleh memiliki hak akses kueri langsung ke tabel Supabase tanpa melalui backend API.
- `[TECHNICAL IMPLEMENTATION]`:
  - Diterapkan `revoke all privileges on all tables in schema public from anon, authenticated;` (migrasi `20261007104906_security_rls.sql` dan `20261008210000_security_hardening.sql`).
  - Seluruh akses database dilakukan secara eksklusif oleh NestJS backend menggunakan Supabase `service_role` key.
- `[TECHNICAL IMPLEMENTATION]`: Tabel `audit_logs` dilindungi trigger PostgreSQL `trg_prevent_audit_log_update_delete` yang membatalkan percobaan operasi `UPDATE` dan `DELETE` demi menjamin integritas forensik (*append-only log*).

---

4. Konvensi API & Penanganan Galat (*Error Handling*)

- `[TECHNICAL IMPLEMENTATION]`:
  - Seluruh rute diawali dengan prefiks global: `/api/v1/`.
  - Format respon sukses terstandarisasi:

```
{
  "success": true,
  "data": { ... },
  "message": "Operasi berhasil dieksekusi."
}
```

  - Format respon galat terstandarisasi via `HttpExceptionFilter`:

```
{
  "success": false,
  "error": {
    "statusCode": 400,
    "code": "BAD_REQUEST",
    "message": "Pesan deskriptif yang aman...",
    "timestamp": "2026-10-08T12:00:00.000Z",
    "path": "/api/v1/applications/..."
  }
}
```

- **Penyensoran Error Kritis**: Jika terjadi kegagalan basis data (PostgreSQL error), kebocoran nama relasi, sintaks query, atau stack trace diblokir total dari klien dan diganti dengan `"Terjadi kesalahan internal pada peladen."`. Detail error teknis hanya dicatat pada log internal server.

---

5. Tata Kelola Penyimpanan Berkas (*Storage Behavior*)

- `[CONFIRMED REQUIREMENT]`: Dokumen permohonan dan lampiran teknis bersifat privat dan tidak boleh dapat diakses melalui URL publik statis.
- `[TECHNICAL IMPLEMENTATION]`:
  - Bucket `simantik-documents` berstatus `public = false`.
  - Ukuran berkas dibatasi maksimal 10 MB per file.
  - Tipe berkas yang diizinkan (*whitelisted MIME*): PDF, DOCX, XLSX, JPEG, PNG.
  - Berkas diunduh melalui *Signed URL* sementara (berlaku 15 menit) yang diterbitkan backend setelah memeriksa hak otorisasi pengguna (`assertTechnicianAssignment` untuk teknisi).
  - Setiap penerbitan signed URL dicatat dalam tabel `audit_logs` (`action = 'DOCUMENT_ACCESSED'`).

---

6. Autentikasi, Otorisasi & Batas Penugasan

A. Autentikasi Staf Diskominfo

- `[TECHNICAL IMPLEMENTATION]`:
  - Menggunakan Supabase Auth (Email & Password).
  - `AuthGuard` memverifikasi token JWT, mengekstrak user ID, dan memeriksa tabel `profiles`.
  - Jika profil tidak ditemukan atau berstatus `is_active: false`, akses ditolak dengan `401 Unauthorized`.

B. Otorisasi Peran (RBAC)

- `[CONFIRMED REQUIREMENT]`:
  - `SUPER_ADMIN`: Akses penuh ke seluruh permohonan, penugasan teknisi, verifikasi, keputusan persetujuan/penolakan, master data, dan audit trail.

    - `TECHNICIAN`: Akses lembar kerja "My Work", pembaruan tahapan siklus hidup, pengujian, pemeliharaan, dan komunikasi khusus pada tiket yang ditugaskan secara aktif kepadanya.

- `[TECHNICAL IMPLEMENTATION]`:
    - `RolesGuard` memvalidasi peran pengguna di level controller.
    - `assertTechnicianAssignment()` pada `AdminApplicationsService` memvalidasi bahwa teknisi hanya dapat melihat detail, melakukan transisi, mencatat catatan internal, atau mengunduh dokumen pada tiket yang ditugaskan kepadanya. Teknisi lain yang mencoba mengakses akan menerima `403 Forbidden`.

---

7. Keamanan Pelacakan Publik (*Public Tracking Security*)

- `[CONFIRMED REQUIREMENT]`: Pemohon OPD dapat melacak tiket tanpa harus membuat akun login, menggunakan Nomor Tiket dan Kode Pelacakan rahasia.
- `[TECHNICAL IMPLEMENTATION]`:
    - **Pencegahan Timing Attack**: Verifikasi hash kode pelacakan menggunakan fungsi konstan `safeHashCompare()` (`crypto.timingSafeEqual`) pada digest SHA-256 32-byte.
    - **Anti-Brute Force**: `TrackingRateLimiter` memblokir akses sementara (HTTP 429) setelah 5 kali kegagalan verifikasi berturut-turut untuk kombinasi IP dan nomor tiket yang sama.
    - **Sesi Sinyal Pendek**: Setelah verifikasi sukses, backend menerbitkan HMAC-SHA256 tracking token berumur 15 menit (`expires_in: 900 detik`).
    - **Data Minimization**: Nama dan email pemohon disamarkan (`Drs. Agus S***` dan `ag***@bandungkab.go.id`). Identitas staf teknisi, catatan telaah internal, dan UUID database internal tidak diekspos ke publik.

---

8. Komunikasi & Isolasi Pesan

- `[CONFIRMED REQUIREMENT]`: Pesan dan catatan internal staf Diskominfo tidak boleh pernah bocor ke kanal pemohon publik.
- `[TECHNICAL IMPLEMENTATION]`:
    - Pesan dipisahkan berdasarkan kolom `visibility`: `PUBLIC` vs `INTERNAL`.
    - Endpoint publik (`GET /api/v1/tracking/:ticketNumber/messages`) menyaring kueri database secara ketat hanya untuk `visibility = 'PUBLIC'`.
    - Pengirim staf internal pada kanal publik disamarkan menjadi identitas generik `"Tim Teknis Diskominfo"` untuk mencegah pengintaian profil staf oleh pihak luar.

---

9. Sistem Notifikasi (In-App & Email)

- `[CONFIRMED REQUIREMENT]` : Notifikasi dikirimkan pada peristiwa penting (permohonan baru, status berubah, tahapan berubah, revisi diminta, penugasan baru, pesan baru, pengujian selesai).
- `[TECHNICAL IMPLEMENTATION]` :
  - **In-App Notifications**: Tersimpan di tabel `notifications` dan ditampilkan pada halaman `/notifications` di Web Admin dengan indikator status baca (*read/unread*).
  - **Email Notifications**: Dikirim dari backend menggunakan SDK Resend. Kunci rahasia `RESEND_API_KEY` disimpan secara eksklusif di backend.
  - **Graceful Fallback**: Jika `RESEND_API_KEY` belum disetel di lingkungan lokal, backend mencatat simulasi email ke logger internal tanpa menghentikan alur aplikasi.
  - **Deduplikasi**: `EmailService` mencegah pengiriman email ganda yang identik dalam rentang waktu singkat.

---

10. Panduan Deployment & Prasyarat Produksi

A. Prasyarat Infrastruktur

1. Node.js runtime versi 20 LTS.
2. Server/Container untuk menjalankan NestJS API (Port 3000).
3. Web Server (Nginx / Cloudflare Pages / Vercel) untuk menyajikan berkas statis `frontend/service-web/dist` dan `frontend/admin-web/dist`.
4. Proyek Supabase dengan database PostgreSQL 15+ dan ekstensi `pgcrypto` aktif.
5. Akun penyedia email transaksional Resend yang telah memverifikasi domain pengirim (misal `bandungkab.go.id`).

B. Langkah Deployment Berurutan

```
# 1. Jalankan Migrasi Basis Data Supabase
supabase db push

# 2. Build Backend API
cd backend/api
npm install --frozen-lockfile
npm run build
# Jalankan menggunakan process manager (misal PM2 atau Docker)
node dist/main.js

# 3. Build Web Layanan
cd ../../frontend/service-web
npm install --frozen-lockfile
npm run build
# Sajikan folder dist/ melalui web server

# 4. Build Web Admin
cd ../admin-web
npm install --frozen-lockfile
npm run build
# Sajikan folder dist/ melalui web server
```

---

11. Batasan yang Diketahui & Pertanyaan Terbuka (*Known Limitations & Open Questions*)

A. Batasan Teknis yang Diketahui (*Known Limitations*)

1. **Penyimpanan Rate Limiting In-Memory**:
   `[IMPLEMENTATION ASSUMPTION]`: `TrackingRateLimiter` saat ini menyimpan penghitung kegagalan dalam memori instance NestJS. Jika backend dijalankan secara kluster/multi-kontainer tanpa *sticky session*, pembatasan percobaan gagal terbagi antar kontainer.
   Saran Mitigasi: Pada deployment produksi skala besar, integrasikan modul Redis untuk sinkronisasi state *rate limit*.
2. **Ketiadaan Pemindaian Antivirus Otomatis pada Berkas Unggahan**:
   `[IMPLEMENTATION ASSUMPTION]`: Sistem saat ini memvalidasi ekstensi berkas, ukuran (10 MB), dan MIME type, namun belum menjalankan *antivirus scanning engine* (ClamAV) sebelum berkas disimpan.
   Saran Mitigasi: Tambahkan *worker pipeline* untuk pemindaian virus berkas sebelum berkas ditandai sah.
3. **Konfigurasi Batas Body Reverse Proxy (50 MB vs 2 MB)**:
   `[TECHNICAL IMPLEMENTATION]`: Backend Express mengizinkan parsing body hingga 50 MB guna mendukung transmisi dokumen lampiran Base64.
   Saran Mitigasi: Lapisan reverse proxy (Nginx/Cloudflare) wajib dikonfigurasi membatasi rute umum ke `2m` dan hanya mengizinkan `50m` pada rute berkas pendaftaran dan siklus hidup (metode POST dan PUT) sesuai panduan di `README.md`.

4. **Risiko Tersisa Cache Idempotency Plaintext**:
   `[TECHNICAL IMPLEMENTATION]` : Cache idempotency memori menyimpan `tracking_code` teks polos selama jendela waktu TTL 10 menit (maksimal 1000 entri) demi mendukung replay pengiriman ulang yang identik pada jaringan tidak stabil.

B. Pertanyaan Terbuka untuk Pemangku Kepentingan Diskominfo (*Open Questions*)

1. `[OPEN QUESTION]` **Integrasi Single Sign-On (SSO) ASN Pemerintah Daerah**:
   Apakah akun pemohon OPD di masa mendatang akan diintegrasikan dengan sistem SSO kepegawaian (misal SIMPEG / KemenPAN-RB) daripada hanya menggunakan sistem tiket berbasis kode pelacakan?
2. `[OPEN QUESTION]` **Kebijakan Tanda Tangan Elektronik Tersertifikasi (BSrE)**:
   Apakah dokumen persetujuan layanan (*Surat Perjanjian/Disposisi*) memerlukan pembubuhan tanda tangan elektronik tersertifikasi (e-Sign BSrE) langsung di dalam sistem SIMANTIK?
3. `[OPEN QUESTION]` **SLA Batas Waktu Verifikasi & Notifikasi WhatsApp**:
   Apakah diperlukan integrasi kanal pemberitahuan pesan instan WhatsApp resmi Pemerintah Kabupaten Bandung selain notifikasi email?

---

12. Lembar Periksa Kesiapan Rilis Akhir (*Final Release Checklist*)

Butir Periksa	Standar Verifikasi	Hasil Pemeriksaan	Status
Typecheck	Bebas dari galat TypeScript pada backend dan kedua frontend (`tsc -b` , `nest build`)	0 type errors	**PASS**
Build Bundles	Kompilasi bundel produksi sukses (`vite build` , `nest build`)	0 build errors	**PASS**
Automated Tests	Seluruh test suite vitest backend lulus 100%	359 passed / 23 test suites (1 skipped: fixture E2E lokal)	**PASS**
No Secret Exposed	Tidak ada API key rahasia, JWT secret, atau Resend key di bundel klien	0 leaks (diverifikasi via ripgrep)	**PASS**
Migration State	Urutan 14 migrasi SQL terdefinisi jelas dan teruji	Terdefinisi di `supabase/migrations/`	**PASS**
Storage State	Bucket `simantik-documents` privat, akses unduh via signed URL	Privat, default deny aktif	**PASS**
Auth State	Autentikasi Supabase Auth aktif dengan validasi profil & status	Terverifikasi via `AuthGuard`	**PASS**
Role Checks	Batasan peran `SUPER_ADMIN` dan `TECHNICIAN` terverifikasi	Terverifikasi via `RolesGuard`	**PASS**
Assignment Boundary	Teknisi tidak dapat mengakses/memutasi tiket teknisi lain	Terverifikasi via `assertTechnicianAssignment`	**PASS**

Butir Periksa	Standar Verifikasi	Hasil Pemeriksaan	Status
Public/Internal Separation	Catatan internal tidak bocor ke endpoint pelacakan publik	Terverifikasi via unit test	**PASS**
Responsive Verification	Tampilan adaptif pada layar Mobile (360px), Tablet (768px), dan Desktop	Terverifikasi pada shell layout	**PASS**
Accessibility Review	Kontras warna, penanda fokus, label input, dialog ARIA modal	Terverifikasi pada komponen UI	**PASS**
Remaining Risks	Risiko sisa didokumentasikan secara jujur dan transparan	Tercantum pada Bagian 11 & docs/ROLLBACK.md	**PASS**

Pernyataan Kesiapan:
SIMANTIK versi 1.0.0 dinyatakan **LULUS TAHAP PENJAMINAN MUTU & SIAP UNTUK TINJAUAN SERAH TERIMA (*READY FOR HANDOVER & USER ACCEPTANCE REVIEW*)**.